V

Document 3 of 3
Companion documents: User Manual · Technical Logic Reference

VISHAL MEGA MART · IT APPLICATIONS

Business Rules & Validations

The controls built into the User Management System and the Asset Management System, for management, process owners and auditors.

Applies to	User Management System (UMS) · Asset Management System (AMS)
Audience	Management, process owners, internal audit, information security
Version	1.0 · October 2026

Contents

1 Executive summary

2 Governance: who owns what

3 Access control rules

4 Sign-in and session security rules

5 Asset management business rules

5.1 Assets · 5.2 Issue and return · 5.3 Requests and approvals · 5.4 Licences · 5.5 Stock · 5.6 Maintenance and audits · 5.7 Disposal · 5.8 Master data

6 Data validations

7 Notifications and management reporting

8 Audit trail and traceability

9 Control status, gaps and recommendations

10 How rules are changed

1 Executive summary

The **User Management System (UMS)** controls who may use each company application and what they may do in it. The **Asset Management System (AMS)** keeps the register of company assets (equipment, software licences and stock), records who holds what, and runs requests, approvals, maintenance and audits.

1	7	7	100%
place where access is decided (UMS) for every application	checks on every action: organisation, person, application, module, permission, location, policy	asset-specific policies (hours, value limits, segregation of duties, MFA, own items…)	of changes and decisions are recorded with who, what, when

Key controls at a glance

No access without a role
Access comes only from roles given in UMS and from approved policies. Nobody, not even the AMS software, can bypass UMS.

Least privilege by location
Roles can be limited to stores, DCs or offices, and to a period (temporary cover ends by itself).

Segregation of duties
Nobody approves their own asset request. Approvers need MFA. Managers cannot dispose high-value assets.

Value-based limits
Assets over ₹1,50,000 are not issued to contract, intern or vendor staff. Refunds over ₹10,000 need a Store Manager.

Secure sessions
One device per person, automatic sign-out when idle, lockout after 5 wrong passwords, admins can end any session.

Fail safe
If the access service cannot be reached, nothing is shown or changed. A missing piece of information never grants access.

Changing a rule needs no software change
Limits, hours, roles and policies are data in UMS. An authorised administrator changes them in the UMS Admin Portal, and the change applies at once to every application. Every change is logged with its before and after values.

2 Governance: who owns what

Responsibility	Owner (role)	Tool
Creating users, giving and removing roles, resetting passwords	UMS Administrator (IT) on request of the line manager / HR	UMS Admin Portal → Users
Defining roles and their permissions	UMS Administrator with the application owner	Roles & Permissions
Policies (hours, limits, segregation of duties)	Process owner approves; UMS Administrator configures	ABAC Policies, Office Hours & Holidays
Security settings (passwords, idle time, lockout, single device)	Information Security	Security Settings
Asset register and master data (models, categories, locations, suppliers)	Asset Administrator (central IT)	AMS → Setup
Day-to-day issue, return, audit and maintenance of a location's assets	Asset Manager of that location	AMS
Approving asset requests	Asset Manager / Administrator (not the requester)	AMS → Asset Requests
Independent review	Internal Auditor (read-only role)	Both portals: audit trail, action trail, reports
Emergency full access	Super Administrator (break-glass only; use is logged)	Both portals

3 Access control rules

These rules apply to every application connected to UMS. AMS is one of them.

3.1 General principles

ID	Rule	Why it matters
AC-01	Every action is checked in seven steps: organisation active → person active and not expired → access to the application → to the module → the exact permission → within the role's locations → company policies. The first failing step refuses the action and shows the reason.	One consistent, explainable decision for all applications.
AC-02	Access comes only from roles (or an approved Grant policy, e.g. "you may see the asset issued to you"). No access is coded into applications.	Access can be reviewed and changed in one place.
AC-03	A role may be limited to locations (stores, DCs, offices). A record outside them is refused.	Least privilege; a store manager cannot act for another store.
AC-04	A role may have start and end dates; outside them it does not count.	Temporary cover ends automatically (no forgotten access).
AC-05	Information that is missing never satisfies a rule: if a record lacks the value a policy checks, a "must" rule fails and an "allow" rule does not apply.	The system fails safe.
AC-06	A person's data is only visible within their organisation (tenant). Only an active Super Administrator can work across organisations.	Separation between Vishal Mega Mart, vendors and test data.
AC-07	UMS protects its own administration with the same rules (e.g. only roles with UMS user-edit permission can change users).	Administrators are controlled like everyone else.

3.2 Company policies configured today

ID	Policy	Type	Applies to
PO-01	Finance executives only during office hours (Mon–Sat 09:30–18:30, not holidays)	Restrict	Finance ERP
PO-02	Payroll only during office hours	Restrict	Payroll
PO-03	Cashiers and supervisors bill only during store hours (08:00–23:00) and only from a POS terminal	Restrict	POS
PO-04	Shift supervisors cannot refund above ₹10,000 (Store Manager needed)	Deny	POS
PO-05	HR executives edit or delete employees of their own region only	Restrict	HRMS

ID	Policy	Type	Applies to
PO-06	Payslips: own record only, unless HR Manager or Payroll Admin	Restrict	HRMS
PO-07	The approver named on a PO may view and approve it	Grant	Procurement
PO-08	No data export from personal / unmanaged devices	Deny	All applications
PO-09	Contract, intern and vendor staff cannot delete records	Deny	All applications
PO-10	Finance approvals need MFA and the office network or VPN	Restrict	Finance ERP
PO-11	Store managers act only on their own store's records	Restrict	Store Operations
PO-12	Vendors see only their own POs, during vendor portal hours	Restrict	Procurement (vendor network)
PO-13 … PO-19	Asset Management policies: see chapter 5		AMS

4 Sign-in and session security rules

ID	Rule	Setting (Vishal Mega Mart)
SS-01	Sign-in needs the company e-mail and password. A wrong e-mail and a wrong password give the same message, so it cannot be used to discover accounts.	—
SS-02	After repeated wrong passwords the account locks for a period.	5 attempts · 30 minutes
SS-03	Inactive, locked or expired accounts (e.g. contract end date passed), and accounts of inactive organisations, cannot sign in. A running session of such an account stops at its next token renewal.	—
SS-04	Signing in is allowed only to applications enabled for the person's organisation.	—
SS-05	**Single-device login**: a new sign-in to an application ends the person's other session in that application; the other device shows why.	On
SS-06	**Idle timeout**: no activity for the set time signs the person out, after a one-minute warning; the session is closed in UMS as "Idle".	30 minutes
SS-07	Short-lived access tokens are renewed silently while the person works. The renewal key changes every time; if an old key is used again (possible theft), the session ends at once.	15 minutes · 7 days maximum
SS-08	Administrators see all active sessions (person, application, device, IP address, times) and can end any session (lost device, leaver).	—
SS-09	Sessions ended by any route (sign out, idle, other device, admin, security) take effect on every connected application, normally within a minute.	Portal check every 60 s
SS-10	Passwords: at least the organisation's minimum length, with upper and lower case letters and a digit. Passwords are stored only as salted hashes.	Minimum 12 characters
SS-11	The web portals keep sign-in credentials on the server, never in the browser. The browser holds only a protected cookie that scripts cannot read, and sign-out cannot be triggered by another website.	—

5 Asset management business rules

5.1 Assets

ID	Rule
AM-01	Every asset has a unique asset tag within the organisation, a name, a model (manufacturer and category), a status and a location.
AM-02	Cost cannot be negative. Book value is calculated straight-line over the category's depreciation period; it reaches zero at the end of that period.
AM-03	Status types decide what can happen: only **Deployable** assets can be issued or requested; Pending, Undeployable (e.g. Broken, Out for Repair) and Archived (Retired) cannot.
AM-04	An Asset Manager sees and changes only assets of their locations, and cannot move an asset to a location outside them (both the current and the new record are checked).
AM-05	Every employee can see the assets issued to them (My Assets), and nothing else unless their role allows it.

5.2 Issue (check-out) and return (check-in)

ID	Rule
AM-10	An asset can be issued only to an **active employee** taken from the UMS directory, and only if it is **not already issued** and its status is **Deployable**.
AM-11	Restrict Assets can be checked out only during **store operating hours**, 08:00–23:00.
AM-12	Deny Assets costing more than **₹1,50,000** cannot be issued to **contract, intern or vendor** staff.
AM-13	The expected return date, if given, cannot be in the past. Assets past their return date appear as **overdue** on the dashboard, in reports and in the daily digest.
AM-14	A return (check-in) is possible only for an issued asset; the asset may be given a new status at return (e.g. Out for Repair).
AM-15	The employee is e-mailed on issue and on return.

5.3 Requests and approvals

ID	Rule
AM-20	Employees can request only assets marked **Requestable**, Deployable and not issued, and must give a reason.
AM-21	A person can have only one pending request for the same asset.
AM-22	Deny **No self-approval**: a request cannot be approved by the person who raised it.
AM-23	Restrict Approving requests requires **MFA** to be enabled for the approver.

ID	Rule
AM-24	Approving also requires permission to issue that asset to that person, so AM-10 to AM-12 apply. Approval issues the asset immediately, and **other pending requests for the same asset are rejected automatically** ("Asset issued to ...").
AM-25	A rejection must state a reason. Requests can be decided or cancelled only while Pending.
AM-26	Restrict A request can be seen or cancelled only by the requester, asset staff or auditors.
AM-27	The asset desk is e-mailed for every new request (requester in copy); the requester is e-mailed the decision.

5.4 Software licences

ID	Rule
AM-30	A licence has at least one seat. Seats cannot be reduced below the number in use.
AM-31	A seat is given to a person and/or installed on an asset; a person can hold only one seat of the same licence.
AM-32	No seat can be given when all seats are used or the licence has **expired**. Licences expiring within 90 days are flagged "renew soon"; those within 30 days appear in the daily digest.
AM-33	Product keys are shown only to people allowed to edit the licence.
AM-34	A licence can be deleted only when all seats are returned.

5.5 Accessories, consumables and components

ID	Rule
AM-40	**Accessories** are lent to a person and returned; one of each item per person.
AM-41	**Consumables** are issued and used up; the quantity issued cannot exceed stock; they cannot be returned.
AM-42	**Components** are installed into an asset and return to stock when removed.
AM-43	Quantities cannot be negative and cannot be reduced below the units currently out. An item's kind cannot change.
AM-44	When available stock is at or below the **re-order level** the item is flagged and listed in the daily digest.
AM-45	An item can be deleted only when all units are back in stock.

5.6 Maintenance and physical audits

ID	Rule
AM-50	Maintenance needs a title. The cost cannot be negative, and the completion date cannot be before the start date. A record cannot be moved to another asset.

ID	Rule
AM-51	Location limits apply to maintenance as to the asset itself.
AM-52	An audit confirms the asset was seen and sets the next audit date, which must be in the future. Audits due within 30 days are on the dashboard, in reports and in the digest.

5.7 Disposal (delete)

ID	Rule
AM-60	An asset can be deleted only when it is checked in.
AM-61	Deny Asset Managers cannot delete assets that cost more than **₹1,00,000**; an Asset Administrator must.
AM-62	Deny Contract, intern and vendor staff cannot delete anything (PO-09).

5.8 Master data

ID	Rule
AM-70	Only Asset Administrators change master data (models, categories, manufacturers, suppliers, locations, departments, status labels); Asset Managers view it.
AM-71	Names are required; category names are unique. Location codes are required, unique, and must match UMS user locations (e.g. S045, DC-NR1, HO-GGN) so that location limits work. A model needs a category and a manufacturer.
AM-72	An entry in use by any record cannot be deleted.

6 Data validations

Validations are enforced on the server. A screen may check too, but the server always does. The message shown to the user is in the right-hand column.

6.1 User Management

Record	Field / rule	Message or effect
User	Full name required, 3–200 characters	Field error
	E-mail required and valid; employee code required (max 50)	Field error
	Role validity: end date not before start date	"Role validity end date is before its start date."
	Password ≥ organisation minimum (and ≥ 8), upper case, lower case, digit	"Password needs an upper-case letter." etc.
Role	Code required (max 50), name required (max 200)	Field error
Application	Code (max 30) and name required; modules and resources need codes; each resource needs at least one action	"Each resource needs at least one action."
Policy	Name required; priority 0–10,000; every condition needs an attribute	Field error
Schedule	Code and name required; at least one time window	"A schedule needs at least one time window."
Security settings	Password minimum 8–128; max failed logins 1–50; token lifetime 1–1440 min; idle timeout, password expiry, lockout and refresh days > 0	Field error
Access check (batch)	At most 2000 checks per call; app, module and resource required	"At most 2000 checks per call."

6.2 Asset Management

Record	Rule	Message
Asset	Tag and name required	"Asset tag and name are required."
	Tag unique	"Asset tag VMM-LT-1007 is already used."
	Cost ≥ 0; model, status and location must exist	"Cost cannot be negative." · "Choose a valid model, status and location."
	Delete only when checked in	"Check the asset in before deleting it."

Record	Rule	Message
Check-out / in	Employee chosen and active	"Choose an employee." · "... is not an active employee."
	Not already issued	"VMM-LT-1007 is already checked out to ..."
	Status deployable	"... is 'Broken'; only deployable assets can be checked out."
	Return date not in the past	"The return date cannot be in the past."
	Check-in only if issued	"... is not checked out."
Audit	Next audit in the future	"The next audit must be in the future."
Request	Reason required	"Please give a reason."
	Asset offered and free	"... is not offered for requests." · "... is already issued."
	One pending per person and asset	"You already have a pending request for this asset."
	Rejection needs a reason	"Give a reason for the rejection."
	Decide or cancel only when pending	"The request is already approved."
Licence	Name required; seats ≥ 1; cost ≥ 0	"A licence needs at least one seat."
	Seats not below seats in use	"3 seats are in use; check some in before reducing seats to 2."
	Seat to a person or an asset	"Choose a person or an asset."
	Seats available, not expired, one per person	"All 25 seats of ... are in use." · "... expired on 31 Mar 2026." · "... already has a seat."
	Delete only with no seats out	"Check in all seats before deleting the licence."
Stock item	Name and location required; quantities and cost ≥ 0	"Quantities cannot be negative." · "Choose a location."
	Quantity not below units out	"4 units are out; quantity cannot be less than that."
	Issue: quantity ≥ 1 and ≤ available; person (or asset for components)	"Only 3 of ... available." · "Choose the asset the component goes into."
	Accessory one per person; consumables not returnable	"... already has one." · "Consumables are used up and cannot be checked in."
	Delete only with all units in; kind cannot change	"Check in all units before deleting." · "The kind of an item cannot change."

Record	Rule	Message
Maintenance	Title; cost ≥ 0; completion ≥ start; stays on its asset	"Completion date cannot be before the start date."
Master data	Name required; category name and location code unique; model needs category and manufacturer; in-use entries not deletable	"Location code S045 already exists." · "Laptops is used by 20 record(s)."

7 Notifications and management reporting

7.1 E-mails

Event	Recipient	Control purpose
Asset issued	Employee	Acknowledgement of custody
Asset returned	Employee	Proof of return
Asset request submitted	IT asset desk (requester in copy)	Timely handling
Request approved / rejected	Requester	Transparency of decisions
Daily digest, 08:30 IST	IT asset desk	Exceptions: overdue returns, audits due (30 days), licences expiring (30 days), low stock. Not sent when there is nothing to report.

E-mail is sent only to approved company domains, so a typo cannot send company data outside. Sending happens in the background; a mail problem never blocks the business transaction.

7.2 Reports available to management

- **AMS Dashboard**:
  - asset count and purchase value, utilisation (issued vs ready);
  - licence seats used, low stock, pending requests, open repairs;
  - breakdowns by category, location and status;
  - audits due, overdue returns, warranties ending within 90 days.
- **AMS Reports**:
  - purchase value, book value and depreciation by category, location and status;
  - a detailed depreciation table, exportable to CSV.
- **Activity Log**: every asset transaction, exportable.
- **UMS Dashboard**:
  - users by status and department;
  - access decisions per application;
  - items needing attention;
  - recent changes.
- Every figure respects the viewer's access. A location manager's report covers only their locations.

8 Audit trail and traceability

Record	What is captured	Where to see it
Changes in UMS	Who, when, what (user, role, policy, settings, session revoke), old and new values, IP address	UMS → Audit Trail
Access decisions	Every allowed or refused action in an application, with the reason, user, route and IP; every sign-in	UMS → User Action Trail
Sessions	Each sign-in: application, device, IP, start, last activity, end and reason	UMS → Active Sessions
Asset transactions	Created, edited, checked out/in, audited, requested, approved, rejected, maintained, deleted: who, when, item, person, note, location	AMS → Activity Log and each asset's history
System errors	Unexpected errors with context, for follow-up	UMS → Exception Logs; AMS log files

9 Control status, gaps and recommendations

Status of each control area as delivered:

Control	Status	Comment / recommendation
Role- and policy-based access (chapters 3, 5)	Enforced	Review roles and scopes every quarter; use the Access Simulator to verify changes.
Single-device login, idle timeout, lockout, token renewal, admin session end	Enforced	Tested end to end.
Password complexity and minimum length	Enforced	Applied when a password is set.
Password expiry (90 days)	Configured, not enforced	The setting is stored but sign-in does not yet force a change. Implement before go-live, or decide to rely on SSO.
Multi-factor authentication	Partly	Policies check whether MFA is enabled on the account (e.g. approvers), but sign-in does not yet ask for a second factor. Integrate an MFA / SSO provider (e.g. Microsoft Entra ID) so that the flag reflects a real second factor.
Allowed IP ranges for admins	Configured, not enforced	Network is used in policies (Office LAN vs Internet); the tenant IP allow-list is not yet applied at sign-in.
Device check (managed / unmanaged)	Configuration	AMS reports the device type from configuration. Connect it to device management (Intune) for a real per-device signal.
Development conveniences	Must be off in production	`Security:RequireAuthentication` must be true; automatic database set-up and demo data off; demo passwords and development keys replaced by secrets.
Data protection of e-mails	Enforced	Configure the allowed e-mail domains in production.

Recommended before go-live

1. Enforce password expiry and connect real MFA (or company SSO).
2. Production settings review (chapter 9 last rows).
3. Role and scope review with process owners.
4. Approve the policy limits (₹1,00,000 disposal; ₹1,50,000 contract staff; operating hours) with Finance and Audit.

10 How rules are changed

1. **Request.** The process owner asks for a change (e.g. "raise the contract-staff limit to ₹2,00,000").
2. **Approve.** The change is approved according to the company's change policy (Information Security and Audit for security-relevant rules).
3. **Test.** The UMS Administrator checks the effect with the Access Simulator, which explains the decision step by step.
4. **Apply.** The administrator edits the policy, role or setting in the UMS Admin Portal. It applies immediately to all applications; no software release is needed.
5. **Evidence.** The Audit Trail records the change with old and new values, who made it and when.

Rules that need a software change

Data rules that protect the integrity of the register (unique tags, no double issue, seat and stock limits, no deletion while in use) are built into the database and apply to every user. Changing them needs a development change and testing.